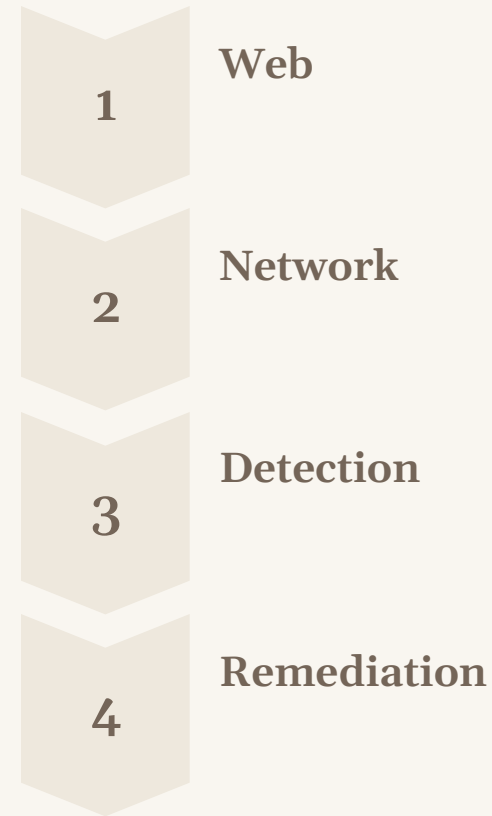




RedScope Capstone Project

Lab-only red-team assessment with detection, evasion validation, remediation, and business-impact mapping



Shamanth R Singh | Ajith Mohan | Saiteja Kacham | Madhurjya Deka

One Assessment Connected the Full Security Lifecycle

Security weaknesses become more serious when they interact across layers.

Simulate

Realistic attacker path in a safe, controlled laboratory

Chain

Identify how web and network weaknesses interact

Validate

Test detection logic and ML detector against modified payloads

Translate

Map technical findings to remediation and business risk



Authorization and Safety Defined Every Test

Responsible cybersecurity testing requires authorization, clear boundaries, documentation, and repeatability.

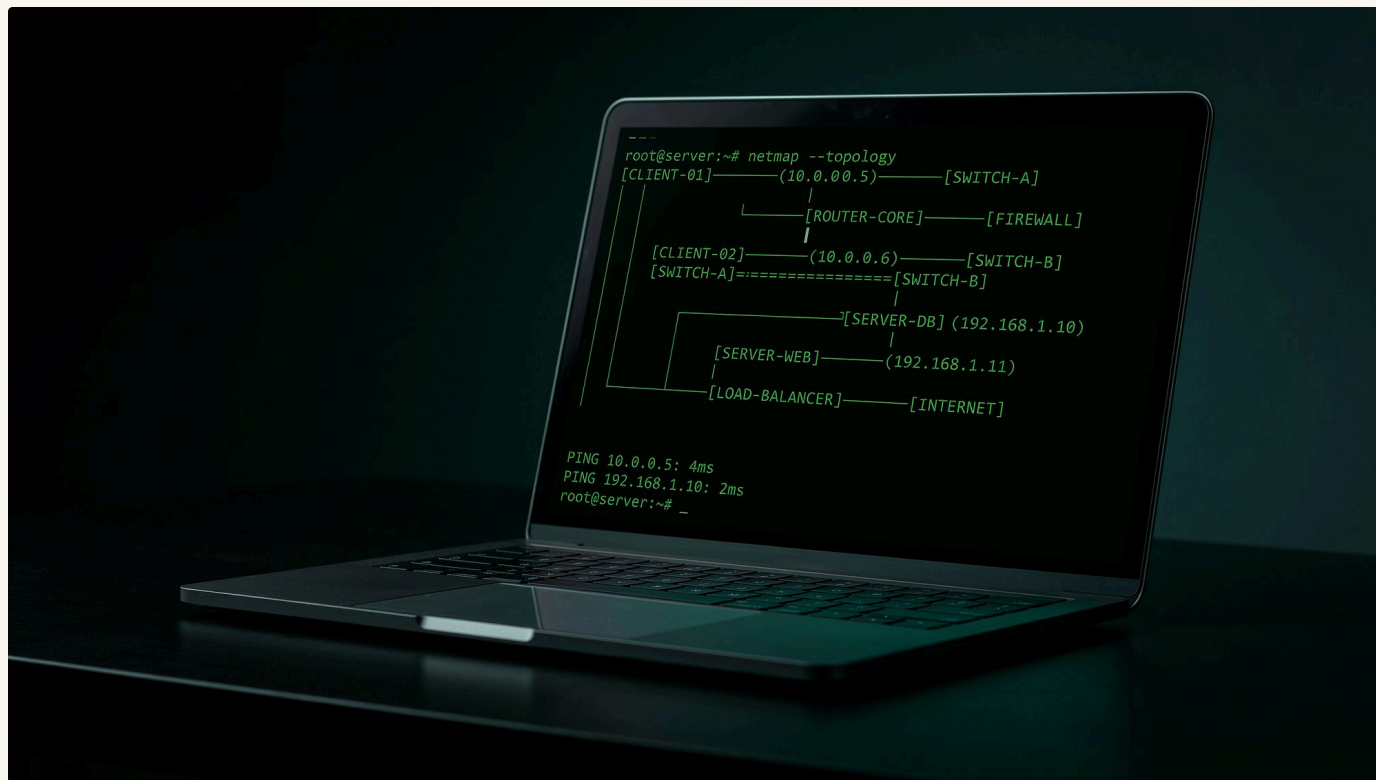
In Scope

- DVWA, OWASP Juice Shop, and Metasploitable 2
- Web and network reconnaissance
- Controlled exploitation and limited post-exploitation
- ML detector and evasion experiments
- Evidence collection, risk analysis, and remediation

Out of Scope

- Public or unauthorized systems
- Denial-of-service activity
- Real data exfiltration
- Credential abuse outside the lab
- Destructive actions or persistence

The Lab Recreated a Small Enterprise Attack Surface



Lab Architecture

- **Attacker:** Kali Linux VM
- **DVWA:** 192.169.1.29:8080 (Kali) / localhost:8080 (host)
- **Juice Shop:** 192.169.1.29:3000 (Kali) / localhost:3000 (host)
- **Network target:** Metasploitable 2 at 10.77.0.3

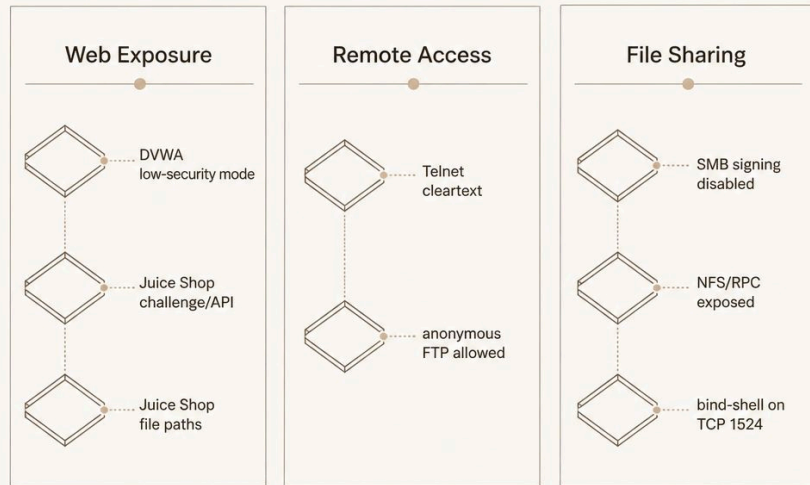
Docker hosted the web applications. VirtualBox hosted the attacker VM and vulnerable network target. All activity remained inside the controlled lab environment.

The Team Followed a Reproducible Red-Team Method

Every finding was connected to evidence, impact, and corrective action.

01	02	03
Planning and Rules of Engagement	Lab Setup and Validation	Reconnaissance and Service Discovery
04	05	06
Vulnerability Analysis	Controlled Web and Network Exploitation	Limited Post-Exploitation Observation
07	08	09
ML Detector Training and Evaluation	Evasion Testing and Defender Comparison	Risk-Based Remediation and Reporting

Reconnaissance Revealed a Broad Legacy Attack Surface



Key Exposures

- FTP, Telnet, SMB, RPC/NFS, HTTP, and a bind-shell service were exposed
- Anonymous FTP access was permitted
- Telnet transmitted credentials in cleartext
- SMB message signing was disabled
- DVWA operated in low-security mode
- Juice Shop exposed challenge, API, and file-directory paths

Ten Findings Created a Clear Risk Hierarchy

The highest priorities were immediate root access, exploitable web input, and unnecessary legacy services.

Severity	Count	Representative Findings
Critical	1	Unauthenticated root bind shell on TCP 1524
High	3	Legacy remote services, legacy web paths, and DVWA SQL injection
Medium	6	Anonymous FTP, cleartext Telnet, unsigned SMB, exposed NFS/RPC, Juice Shop routes, and exposed files

1
Critical

6
Medium

3
High

10
Total Findings

DVWA SQL Injection Exposed Weak Input Handling

```
mysql> SELECT id, username, email, role FROM users WHERE active = 1
```

	id	username	email	role
		admin	admin@company.com	admin
1	1	admin	rdmmsesn@company.com	admin
2	2	jsmith	j.smith@company.com	user
3	3	mwilliams	m.williams@company.com	editor
4	4	rjohnson	r.johnson@company.com	user
5	5	lchen	r.johnson@company.com	user
5	5	lchen	l.chen@company.com	analyst
6	6	kpatel	k.patel@company.com	user
7	7	dlee	d.lee@company.com	editor

7 rows in set (0.043 sec)

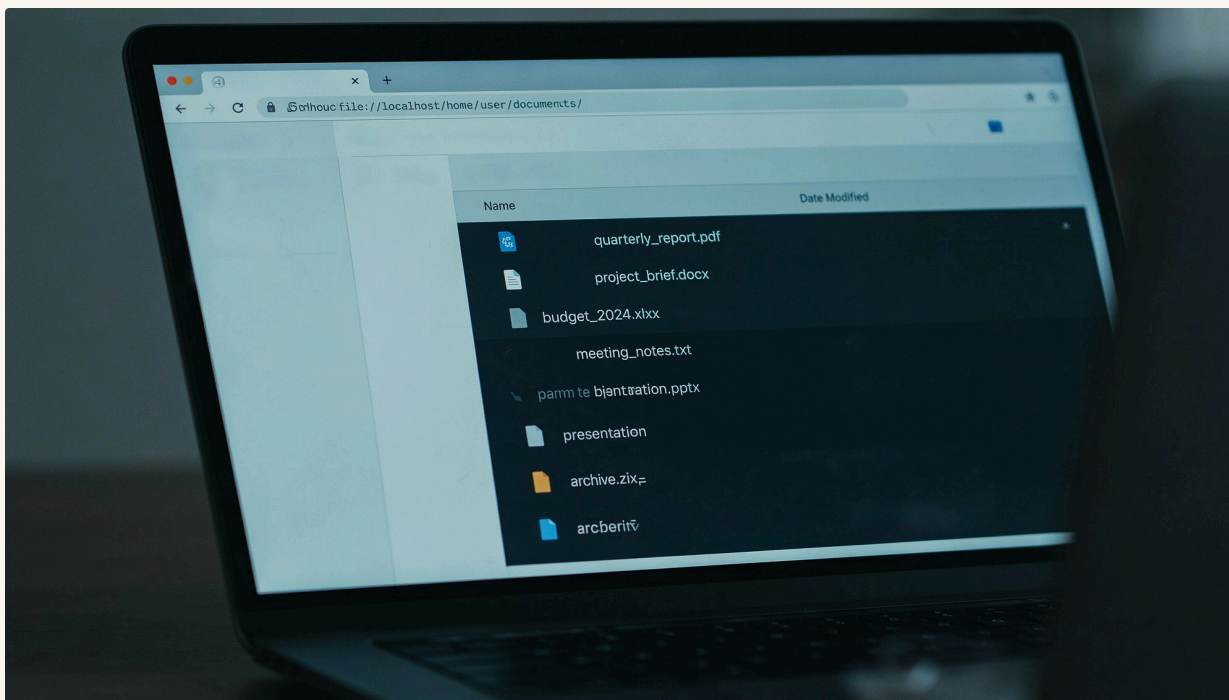
```
mysql> _
```

Finding Detail

- **Target:** DVWA in low-security mode
- **Test input:** `1' OR '1'='1`
- Application returned multiple database rows
- User input successfully altered the SQL query structure
- **Impact:** Unauthorized data access, authentication bypass, or data manipulation

📄 **Remediation:** Use parameterized queries, server-side validation, least-privilege database accounts, and enforce secure production settings.

Juice Shop Exposed Files Through Directory Listing



Finding Detail — **Medium Severity**

- **Target:** Juice Shop /ftp directory
- Directory contents were browsable without intended authorization
- Exposed items included legal documents, acquisition information, encrypted announcements, and KeePass-related files
- Demonstrated insecure content hosting and weak access control
- Exposed documents could support reconnaissance and follow-on attacks

📋 **Remediation:** Disable directory listing, remove unnecessary deployment files, restrict sensitive documents, and enforce authorization checks.

An Exposed Bind Shell Provided Immediate Root Access

⚠ CRITICAL FINDING

```
root@server:~#_
```

Attack Path

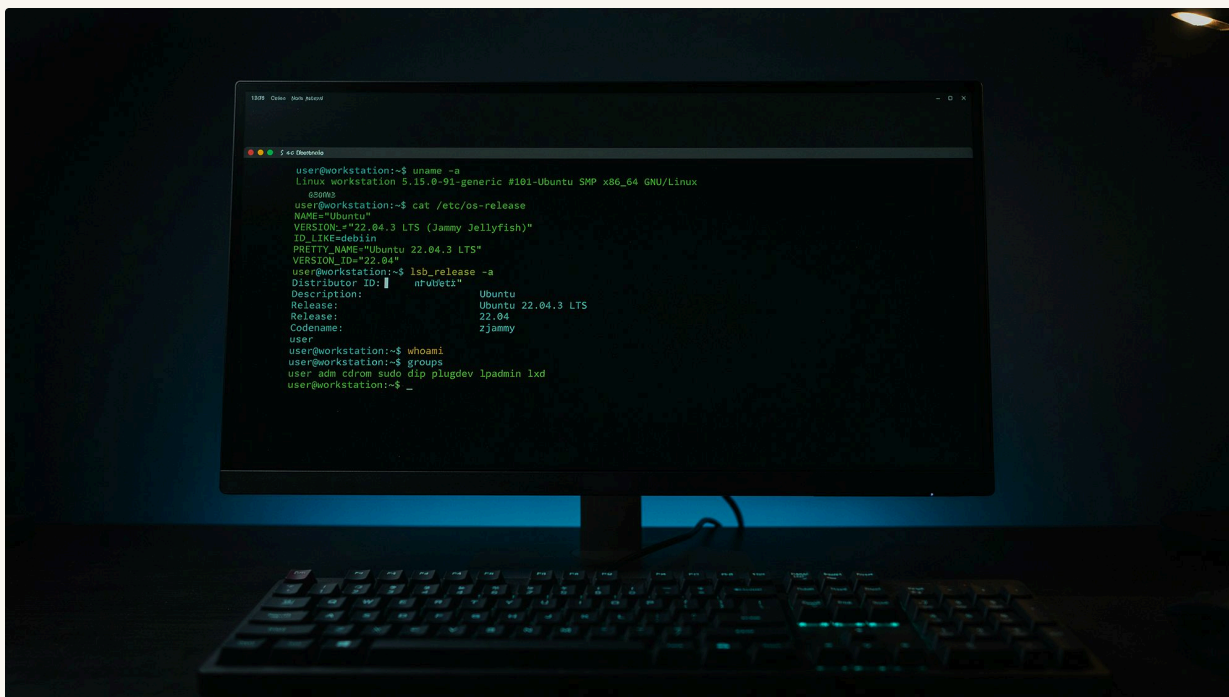
- **Target:** 10.77.0.3:1524
- Service accepted an unauthenticated netcat connection
- The id command returned uid=0(root)
- No password, credential theft, or exploit chain required

Business Impact

- Complete system compromise
- Service disruption risk
- Full data exposure
- Possible path to lateral movement

📋 **Remediation:** Isolate the host, remove the service, block the port, investigate thoroughly, and rebuild from a trusted image.

Post-Exploitation Testing Measured Impact Without Persistence



What Was Observed

- Confirmed user and privilege context
- Recorded hostname, kernel, and OS details
- Reviewed network configuration and interfaces
- Did not install persistence mechanisms
- Did not perform destructive actions or real data movement

Defensive Lessons

- Segment vulnerable systems and enforce least privilege
- Monitor unusual service access and privileged sessions
- Respond quickly to any root-level activity

MITRE ATT&CK Connected Actions to Defender Visibility

Technique mapping helps defenders convert offensive evidence into logging, monitoring, and detection requirements.

Activity	MITRE ATT&CK Technique
Service and vulnerability discovery	T1595 — Active Scanning
Web exploitation	T1190 — Exploit Public-Facing Application
Exposed remote services	T1133 — External Remote Services
Host enumeration	T1082 — System Information Discovery
Network enumeration	T1016 — System Network Configuration Discovery
Access to exposed files	T1213 — Data from Information Repositories

The Baseline ML Detector Worked, but Missed an Attack

Model Configuration

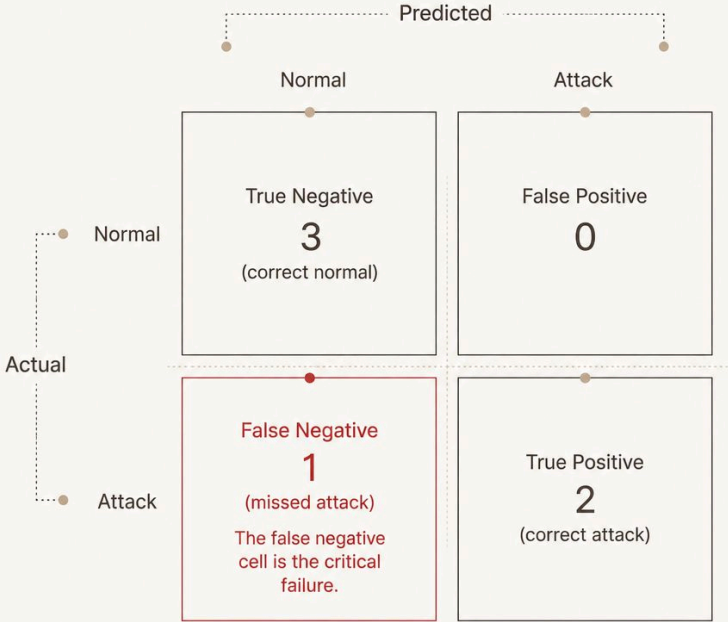
- **Dataset:** 20 HTTP requests (10 normal, 10 attack)
- **Model:** Word-token TF-IDF with Logistic Regression

Performance Metrics

Metric	Result
Accuracy	83.33%
Attack Precision	100%
Attack Recall	66.67%
Attack F1 Score	80%
Confusion Matrix	[[3, 0], [1, 2]]



Overall accuracy appeared acceptable, but the model missed one malicious sample. In security, that false negative matters.



Evasion Testing Exposed the Cost of Narrow Training Data

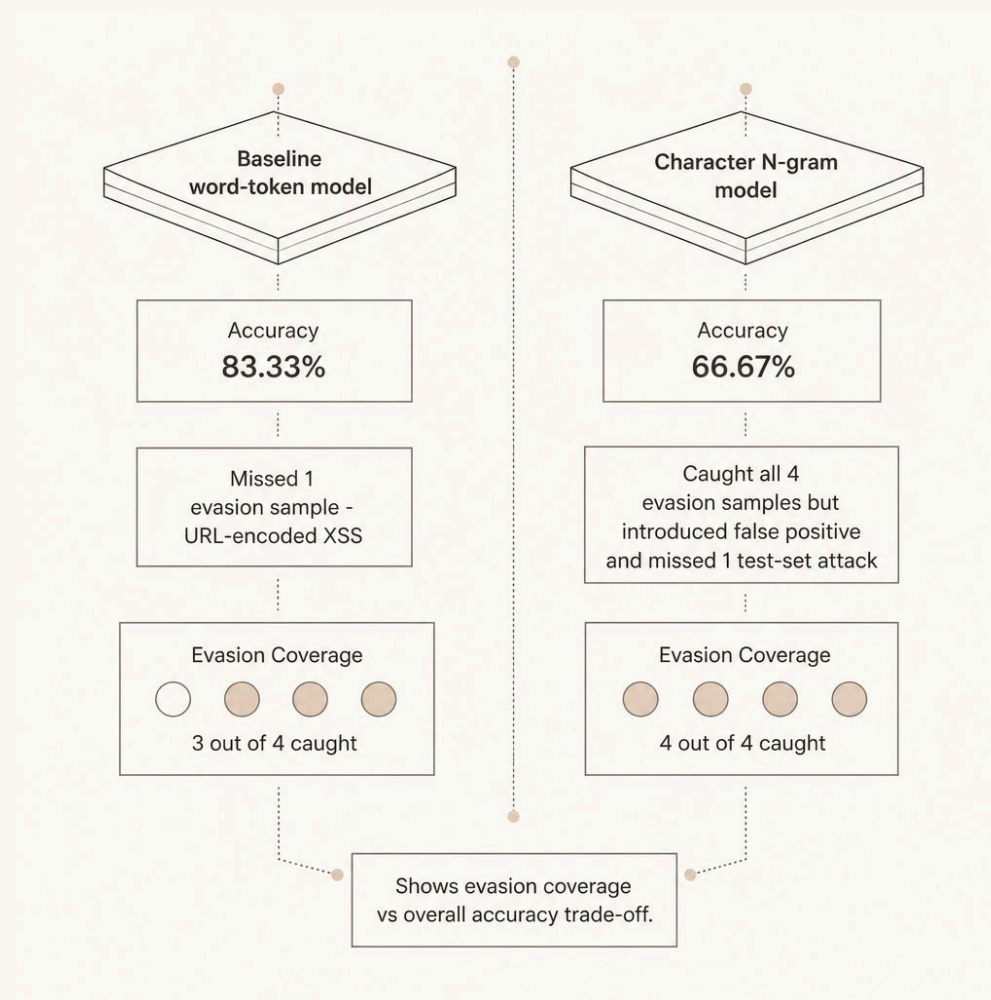
The character model improved evasion coverage but introduced new trade-offs. ML must complement normalization, rules, behavioral analytics, and human review.

Baseline (Word-Token)

- Detected 3 of 4 evasion samples
- URL-encoded XSS classified as **normal** — missed
- SQL injection variants remained flagged as attacks

Character N-Gram Defender

- Detected all 4 evasion samples
- Accuracy: 66.67%
- Introduced a false positive and missed a separate test-set attack
- Improved evasion coverage created detection trade-offs



Remediation Should Reduce Entry, Movement, and Detection Gaps

Immediate

- Remove TCP 1524 bind shell and isolate the affected VM
- Disable unnecessary FTP, Telnet, NFS/RPC, SMB, and legacy web services
- Block unnecessary ports and remove anonymous or cleartext access

Near Term

- Use parameterized queries and server-side input validation
- Restrict exposed directories, backups, and sensitive files
- Enforce network segmentation, least privilege, and authentication logging

Long Term

- Train detectors with larger, more varied datasets including encoded and obfuscated samples
- Normalize and decode requests before classification
- Combine ML, rules, behavioral detection, threat intelligence, and response playbooks

RedScope Turned Controlled Testing into Practical Risk Reduction

10 Findings

1 Critical, 3 High, 6 Medium — fully documented with evidence

Full Lifecycle

Offense, detection, and remediation connected in one assessment

ML Validated

Detection tested against evasion — not assumed to work

Risk Mapped

Findings translated to business impact and corrective action

RedScope demonstrates how authorized, repeatable security testing can become measurable business risk reduction.

Questions and Discussion / RedScope Capstone Project

